



Augmented Cyber Risk Analysis

Rapport d'audit UX / Design

Heuristiques de Nielsen · WCAG 2.1 AA · Principes Gestalt

Score UX composite : **7.1 / 10** (Acceptable)

Périmètre : application web Next.js — 20 écrans authentifiés
Mode d'accès : session authentifiée (rôle ADMINISTRATEUR)
Date de capture : 10 juin 2026

Sommaire

(Dans Word : clic droit sur le sommaire → « Mettre à jour les champs ».)

1. Résumé exécutif

ACRA guide des non-spécialistes dans la conduite d'une analyse de risques EBIOS Risk Manager (compatible ISO 27005). L'audit a porté sur l'ensemble du parcours authentifié : connexion, tableau de bord, gestion des analyses, les cinq ateliers EBIOS RM, la vue des risques, le plan d'action, la configuration des échelles, le profil et la console d'administration.

Verdict global : l'application offre une expérience solide et cohérente (score composite 7.1/10 — **Acceptable**). Sa grande force est l'accompagnement pédagogique d'un référentiel complexe. Les axes de progrès se concentrent sur l'accessibilité (icônes émojis, contrastes) et quelques finitions (locale des dates, micro-typographie, confirmations).

Tableau de synthèse des scores

Référentiel	Score / 10	Lecture
Heuristiques de Nielsen (utilisabilité)	7.5	Parcours guidé, progression très lisible
WCAG 2.1 AA (accessibilité)	6.3	12/19 critères évalués conformes
Principes Gestalt (perception visuelle)	7.5	Hiérarchie et regroupements clairs
SCORE UX COMPOSITE	7.1	Acceptable

Pondération : Nielsen 45 % · WCAG 30 % · Gestalt 25 %.

Top 3 des points forts

- **Accompagnement pédagogique exemplaire** — encadrés « Comment ça marche ? », exemples concrets dans chaque atelier, guide EBIOS RM sur le tableau de bord et descriptions de rôles intégrées. Un référentiel complexe rendu abordable pour des non-experts.
- **Visibilité de la progression** — steppers des 5 ateliers, pourcentages d'avancement, badges de statut (En cours / Approuvé) et compteurs (3/3 sources, 6/6 scénarios) maintiennent l'utilisateur orienté à tout moment.
- **Rigueur des formulaires et de la donnée de risque** — labels toujours visibles, textes d'aide, interface en 5 langues, et scores de risque exprimés en valeur + libellé (12/16 Critique) plutôt que par la seule couleur.

Top 5 des axes d'amélioration prioritaires

- **Émojis utilisés comme icônes fonctionnelles** (navigation, exports, KPIs, corbeille) : rendu incohérent selon l'OS, registre peu professionnel pour un outil GRC et noms accessibles manquants. → Remplacer par une bibliothèque d'icônes SVG avec aria-label.
- **Format de date en japonais** (« 6 月 9 日 ») sur le tableau de bord d'administration et le journal d'audit : la locale n'est pas fixée pour le formatage. → Forcer fr-FR via Intl.DateTimeFormat.
- **Contrastes insuffisants** des textes secondaires, placeholders et composants (bordures, toggles) sur fond sombre. → Vérifier et corriger pour atteindre 4.5:1 (texte) et 3:1 (composants).
- **Bandeau cookies recouvrant** qui masque le bas de page (cartes « Apparence » du profil, boutons d'enregistrement). → Réserver l'espace ou positionner le bandeau sans recouvrement.

- **Finitions de confiance** — espaces manquants dans le bandeau cookies (« nécessaires à »), absence de lien « Mot de passe oublié » à la connexion, et actions destructives (corbeille) sans confirmation visible. → Corriger la micro-typographie, ajouter la récupération de mot de passe et des dialogues de confirmation.

2. Méthodologie

Périmètre analysé

Vingt vues ont été capturées en session authentifiée (rôle Administrateur) le 10 juin 2026, puis analysées visuellement. Les données affichées proviennent d'une analyse de démonstration réaliste (« CHU Métropole — Sécurité SI Patient »).

- Authentification : connexion, inscription.
- Pilotage : tableau de bord, liste des analyses, création d'analyse, détail d'analyse.
- Cœur métier : ateliers EBIOS RM 1 à 5 (cadrage, sources de risque, scénarios stratégiques, scénarios opérationnels, traitement).
- Transverse : vue globale des risques, plan d'action, configuration des échelles, profil.
- Administration : tableau de bord admin, utilisateurs, sécurité (politique de mots de passe), journal d'audit.
- Légal : mentions légales, politique de confidentialité.

Référentiels utilisés

- **10 heuristiques de Nielsen** — évaluation de l'utilisabilité.
- **WCAG 2.1 niveau AA** — accessibilité, selon les 4 principes (Perceptible, Utilisable, Compréhensible, Robuste).
- **Principes Gestalt** — cohérence et perception visuelle.

Grille de scoring

Score	Niveau	Signification
0	Bloquant	Empêche l'utilisation — à corriger avant mise en production.
1	Critique	Dégrade fortement l'expérience — sprint suivant.
2	À améliorer	Friction notable — backlog proche.
3	Acceptable	Conforme aux standards, améliorable à la marge.
4	Excellent	Dépasse les attentes — référence à conserver.

Limites de l'audit

Analyse fondée sur des captures statiques en thème sombre, à 1440 px. Les mesures de contraste sont des estimations visuelles (non instrumentées) ; les états dynamiques (focus clavier, survols, messages d'erreur runtime, vue mobile < 768 px) n'ont pas été testés et sont notés « à vérifier » dans la grille WCAG.

3. Analyse Nielsen — 10 heuristiques

Score Nielsen : **7.5 / 10** (moyenne 3.0/4 sur 10 heuristiques)

Réf.	Heuristique	Score
H1	Visibilité de l'état du système	3 · Acceptable
H2	Correspondance système / monde réel	3 · Acceptable
H3	Contrôle utilisateur et liberté	2 · À améliorer
H4	Cohérence et standards	3 · Acceptable
H5	Prévention des erreurs	3 · Acceptable
H6	Reconnaissance plutôt que rappel	4 · Excellent
H7	Flexibilité et efficacité	3 · Acceptable
H8	Design esthétique et minimaliste	3 · Acceptable
H9	Aide à la récupération des erreurs	2 · À améliorer
H10	Aide et documentation	4 · Excellent

Constats détaillés

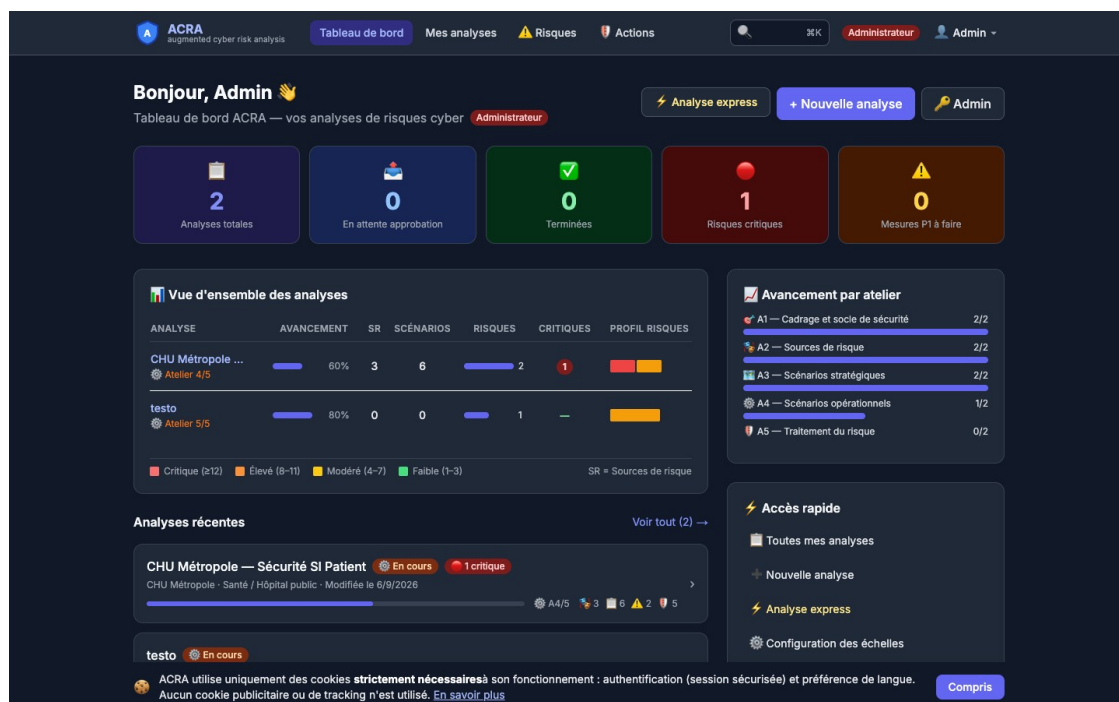


Tableau de bord — KPIs, vue d'ensemble des analyses et avancement par atelier.

[Détail analyse > Stepper de progression] — Progression toujours visible (point fort)

Observation : Chaque analyse affiche un stepper des 5 ateliers avec états (validé ✓, en cours, verrouillé), un pourcentage global et des compteurs d'objets (3/3 sources, 6/6 scénarios).

Impact utilisateur : L'utilisateur sait en permanence où il en est dans un processus long et séquentiel.

Recommandation : Conserver ce modèle ; ajouter un retour explicite de sauvegarde (toast « Enregistré ») là où il n'est pas confirmé (H1).

Priorité : Mineur **Effort** : Faible (< 2h)

[Global > Iconographie] — Émojis employés comme icônes fonctionnelles

Observation : Émojis utilisés pour la navigation, les boutons d'export (PDF/Excel/CSV/JSON), les KPIs et l'action de suppression (corbeille).

Impact utilisateur : Rendu et alignement incohérents selon l'OS/police, registre informel pour un outil GRC, et action non annoncée aux lecteurs d'écran.

Recommandation : Remplacer les émojis par une bibliothèque d'icônes SVG (Lucide, Heroicons) avec aria-label, pour la cohérence (H4) et l'accessibilité (WCAG 1.1.1/4.1.2).

Priorité : Critique **Effort** : Moyen (0.5–2j)

[Atelier 1 > Encadrés d'aide] — Aide contextuelle riche (point fort)

Observation : Chaque atelier ouvre sur un encadré explicatif et propose des exemples concrets sectoriels ; le tableau de bord embarque un « Guide — Ateliers EBIOS RM ».

Impact utilisateur : Réduit fortement la courbe d'apprentissage d'un référentiel exigeant pour un public non-expert.

Recommandation : Maintenir ; envisager une aide « juste-à-temps » repliable pour les utilisateurs experts afin d'alléger l'écran (H7/H8).

Priorité : Mineur **Effort** : Moyen (0.5–2j)

[Analyses / Admin > Actions destructives] — Suppression sans garde-fou visible

Observation : Les analyses (icône corbeille) et les comptes utilisateurs (« Supprimer ») exposent des actions irréversibles sans confirmation apparente.

Impact utilisateur : Risque de perte de données ou de suppression de compte par erreur (H3/H5).

Recommandation : Ajouter un dialogue de confirmation décrivant l'objet supprimé (et son caractère définitif) avant exécution.

Priorité : Critique **Effort** : Faible (< 2h)

[Connexion > Récupération de compte] — Pas de « Mot de passe oublié »

Observation : L'écran de connexion propose « Se connecter » et « Créer un compte » mais aucun lien de réinitialisation de mot de passe.

Impact utilisateur : Un utilisateur ayant oublié son mot de passe est bloqué, sans sortie de secours (H3).

Recommandation : Ajouter un lien « Mot de passe oublié ? » déclenchant un flux de réinitialisation.

Priorité : Amélioration **Effort** : Moyen (0.5–2j)

[Global > Recherche] — Accélérateurs pour utilisateurs avancés (point fort)

Observation : Palette de recherche avec raccourci ⌘K, filtres par statut/priorité/niveau, et « Analyse express » pour démarrer rapidement.

Impact utilisateur : Les utilisateurs réguliers gagnent en efficacité sans pénaliser les débutants.

Recommandation : Documenter les raccourcis (page d'aide ou indice au survol) pour favoriser leur découverte (H7).

Priorité : Mineur **Effort** : Faible (< 2h)

4. Analyse WCAG 2.1 — Accessibilité

Score WCAG : 6.3 / 10 (12 conformes / 19 critères évalués ; 5 non testés)

Réf.	Critère	Niv.	Statut	Constat
1.1.1	Contenu non textuel	A	Non conforme	Les icônes sont des émojis (corbeille, exports, KPIs) sans alternative textuelle exploitable.
1.3.1	Information et relations	A	Conforme	Labels visibles, structure en sections et tableaux sémantiques.
1.3.3	Caractéristiques sensorielles	A	Conforme	Pas d'instruction reposant uniquement sur la forme/position.
1.4.1	Utilisation de la couleur	A	Conforme	Les scores de risque combinent valeur (12/16) + libellé, pas seulement la couleur.
1.4.3	Contraste (texte)	AA	Non conforme	Textes secondaires gris et placeholders sur fond sombre potentiellement < 4.5:1.
1.4.4	Redimensionnement texte 200 %	AA	À vérifier	Non testé sur cette campagne.
1.4.10	Redistribution 320 px	AA	À vérifier	Vue mobile non capturée.
1.4.11	Contraste des composants	AA	Non conforme	Bordures de champs et toggles à faible contraste sur fond sombre.
1.4.12	Espacement du texte	AA	À vérifier	Non testé.
2.1.1	Clavier	A	Conforme	Composants natifs + palette ⌘K suggérant un support clavier.
2.1.2	Pas de piège clavier	A	Conforme	Aucun piège détecté sur les vues inspectées.
2.4.1	Contournement de blocs	A	Non conforme	Lien « aller au contenu principal » non détecté.
2.4.3	Ordre du focus	A	Conforme	Ordre DOM logique (vertical, gauche-droite).
2.4.4	Objet du lien	A	Conforme	Liens explicites (« Traiter → », « Voir tout »).
2.4.6	En-têtes et étiquettes	AA	Conforme	Titres et labels descriptifs, hiérarchie claire.
2.4.7	Visibilité du focus	AA	À vérifier	Anneau de focus non observable sur captures.
2.5.3	Étiquette dans le nom	A	Non conforme	Boutons icône-seule (corbeille, exports) : nom accessible probablement absent.
3.1.1	Langue de la page	A	Non conforme	Dates rendues au format japonais (6 月 9 日) : locale non fixée pour le formatage.
3.2.1	Au focus	A	Conforme	Pas de changement de contexte au focus.
3.2.2	À la saisie	A	Conforme	Saisie sans effet de bord inattendu.
3.3.1	Identification des erreurs	A	À vérifier	Champs requis marqués ;

Réf.	Critère	Niv.	Statut	Constat
				messages d'erreur runtime non capturés.
3.3.2	Étiquettes ou instructions	A	Conforme	Labels visibles systématiques + textes d'aide. Point fort.
3.3.4	Prévention des erreurs	AA	Conforme	Avertissement avant changement d'échelle ; e-mail non modifiable expliqué.
4.1.2	Nom, rôle, valeur	A	Non conforme	Boutons icône-seule et toggles : rôles/états ARIA à confirmer.

Points marquants par catégorie

Perceptible — bon usage non-color-only des risques (1.4.1) ; à corriger : alternatives textuelles des icônes émojis (1.1.1) et contrastes du texte secondaire et des composants sur fond sombre (1.4.3 / 1.4.11).

Utilisable — libellés et en-têtes descriptifs (2.4.6), liens explicites (2.4.4) ; manque un lien d'évitement (2.4.1) et des noms accessibles sur les boutons icône-seule (2.5.3).

Compréhensible — force majeure du produit : labels visibles et instructions systématiques (3.3.2). Réserve : le formatage des dates n'est pas fixé sur la locale française (3.1.1).

Robuste — composants natifs globalement sains ; à fiabiliser : rôles/états ARIA des boutons icône et des toggles (4.1.2).

The screenshot shows the 'Journal d'audit' (Audit Log) section of the ACRA application. The interface includes a top navigation bar with 'ACRA augmented cyber risk analysis', 'Tableau de bord', 'Mes analyses', 'Risques', and 'Actions'. Below this is a sub-navigation bar with 'Dashboard', 'Utilisateurs', 'Sécurité', and 'Journal d'audit'. The main content area displays '12 événements enregistrés' (12 recorded events) and a table of audit logs. The table has columns for Date, Action, Utilisateur, Rôle, IP, Cible, and Détails. The dates are displayed in Japanese format (YY/MM/DD HH:MM:SS). At the bottom, a note states: 'ACRA utilise uniquement des cookies strictement nécessaires à son fonctionnement : authentification (session sécurisée) et préférence de langue. Aucun cookie publicitaire ou de tracking n'est utilisé. En savoir plus'.

Date	Action	Utilisateur	Rôle	IP	Cible	Détails
2026/06/09 23:38:30	ANALYSE_DELETED	cmq1hrt0d0000vopses392...	ADMIN	192.168.65.1	analyse	Voir
2026/06/09 23:28:35	ANALYSE_CREATED	cmq1hrt0d0000vopses392...	ADMIN	192.168.65.1	analyse	Voir
2026/06/09 13:21:00	ANALYSE_APPROVED	cmq1hrt0d0000vopses392...	ADMIN	192.168.65.1	analyse	Voir
2026/06/09 13:09:35	LOGIN_SUCCESS	rodrigo@jokari.io	ADMIN	—	—	—
2026/06/09 08:49:28	LOGIN_SUCCESS	rodrigo@jokari.io	ANALYSTE	—	—	—
2026/06/09 08:22:48	LOGIN_SUCCESS	rodrigo@jokari.io	ANALYSTE	—	—	—
2026/06/07 08:17:00	LOGIN_SUCCESS	rodrigo@jokari.io	ANALYSTE	—	—	—
2026/06/07 08:16:54	LOGIN_FAILED	brice.dudout@gmail.com	—	—	—	Voir
2026/06/06 08:55:38	ANALYSE_SUBMITTED	cmq1hrt0d0000vopses392...	ANALYSTE	192.168.65.1	analyse	Voir
2026/06/06 08:41:17	ANALYSE_CREATED	cmq1hrt0d0000vopses392...	ANALYSTE	192.168.65.1	analyse	Voir

Journal d'audit — les horodatages s'affichent au format japonais (« 6 月 9 日 »), symptôme d'une locale non fixée.

5. Analyse Gestalt — Perception visuelle

Score Gestalt : 7.5 / 10 (moyenne 3.0/4 sur 5 principes évalués)

Réf.	Principe	Score	Constat
G1	Proximité	3 · Acceptable	Cartes regroupant les informations liées, espacements cohérents séparant les groupes.
G2	Similarité	3 · Acceptable	Styles de boutons cohérents et couleurs sémantiques (rouge=critique, vert=résiduel) ; émojis hétérogènes en réserve.
G3	Continuité	3 · Acceptable	Tableaux alignés et steppers d'ateliers guidant le regard d'une étape à l'autre.
G4	Clôture	3 · Acceptable	Cartes et conteneurs bien délimités, troncatures signalées par « ... ».
G5	Figure / Fond	3 · Acceptable	Thème sombre faisant ressortir les cartes ; quelques panneaux à faible séparation et bandeau cookies recouvrant.
G6	Destin commun	N/A	Animations/états de survol non évaluables sur captures statiques.

Vue globale des risques — alignement en colonnes, scores codés valeur+couleur, filtres par niveau.

Synthèse — la perception visuelle est maîtrisée : regroupements par cartes (proximité), couleurs sémantiques cohérentes (similarité), alignements de tableaux nets (continuité) et conteneurs bien délimités (clôture). Les seuls bémols touchent la relation figure/fond — quelques panneaux peu séparés du fond sombre et le bandeau cookies qui recouvre le contenu bas de page.

6. Roadmap de corrections

Actions classées par priorité décroissante. L'effort est indicatif (un développeur familier de la base).

#	Action	Priorité	Effort	Impact	Équipe
1	Confirmation des actions destructives (suppression analyse / compte)	Critique	Faible	Élevé	Front
2	Remplacer les émojis par des icônes SVG + aria-label	Critique	Moyen	Élevé	Front / Design
3	Fixer la locale fr-FR du formatage des dates	Critique	Faible	Moyen	Front
4	Corriger les contrastes (texte secondaire, placeholders, composants)	Amélioration	Moyen	Élevé	Design / Front
5	Repositionner le bandeau cookies (sans recouvrement)	Amélioration	Faible	Moyen	Front
6	Ajouter le lien « Mot de passe oublié »	Amélioration	Moyen	Moyen	Full-stack
7	Corriger la micro-typographie du bandeau cookies (espaces)	Mineur	Faible	Faible	Front
8	Lien d'évitement « aller au contenu principal »	Amélioration	Faible	Moyen	Front
9	Rendre le focus clavier visible et documenter les raccourcis	Amélioration	Moyen	Moyen	Front
10	Retour de sauvegarde explicite (toasts) sur les ateliers	Mineur	Faible	Moyen	Front

Séquencement conseillé : traiter d'abord les éléments 1 à 3 (gains de sécurité d'usage, d'accessibilité et de crédibilité à faible coût), puis la passe contraste (4) et les finitions (5 à 10).

7. Annexes

Glossaire

- **EBIOS RM** — méthode française d'analyse de risques cyber (ANSSI), structurée en 5 ateliers.
- **Heuristiques de Nielsen** — 10 grands principes d'utilisabilité des interfaces.
- **WCAG 2.1 AA** — normes d'accessibilité du W3C ; AA est le niveau de référence réglementaire.
- **Gestalt** — principes de perception visuelle (proximité, similarité, continuité, clôture, figure/fond, destin commun).
- **GRC** — Gouvernance, Risques et Conformité.

Ressources & outils recommandés

- Nielsen Norman Group — 10 heuristiques : nngroup.com/articles/ten-usability-heuristics/
- WCAG 2.1 (W3C) : w3.org/TR/WCAG21/
- Vérificateur de contraste : webaim.org/resources/contrastchecker/
- ARIA Authoring Practices : w3.org/WAI/ARIA/apg/
- Bibliothèques d'icônes SVG : lucide.dev · heroicons.com

Inventaire des écrans illustrés

Nouvelle analyse ACRA
Commençons par quelques informations générales sur votre analyse.

Comment ça marche ?
Vous serez guidé à travers les 5 ateliers EBIOS RM de façon séquentielle. À chaque étape, des exemples et suggestions vous aideront à compléter l'analyse. Vous pouvez sauvegarder et reprendre à tout moment.

Nom de l'analyse *
Ex : Analyse de risques SI RH 2025, Audit cybersécurité application web...
Donnez un nom descriptif et unique à cette analyse.

Organisation / Entité analysée
Ex : Acme Corp, Direction des Systèmes d'Information...

Secteur d'activité
Sélectionner un secteur...
Le secteur permet d'affiner les suggestions et exemples proposés.

Description (facultatif)
Contexte de l'analyse, raison de la démarche, périmètre général...

Annuler **Démarrer l'analyse →**

ACRA utilise uniquement des cookies **strictement nécessaires** à son fonctionnement : authentification (session sécurisée) et préférence de langue. [En savoir plus](#)

Compris

Création d'analyse — labels visibles, champ requis marqué, aide contextuelle.

Profil — sélecteur de langue (5 langues) et thème ; le bandeau cookies recouvre les cartes « Apparence ».

Sécurité — politique de mots de passe et verrouillage de compte entièrement configurables.